

Evaluating Indirect Prompt Injection in RAG Systems: Defense-in-Depth, Retrieval Effects, and Security–Utility Trade-offs

Yulliwas Ameur^{*†}, Miqueas Pedro Mendes[†], Samia Bouzefrane[†], Lyes Khoukhi[†]

^{*}Efrei Research Lab, Efrei, Université Paris-Panthéon-Assas, Villejuif, France

[†]Centre d'études et de recherche en informatique et communications (Cédric),

Conservatoire national des arts et métiers (Cnam), Paris, France

Emails: yulliwas.ameur@efrei.fr, miqueasmendes@gmail.com, samia.bouzefrane@lecnam.net, lyes.khoukhi@lecnam.net

Abstract—IPI robustness in RAG is not a model-only property: it emerges from the interaction between retrieval exposure, prompt assembly, and defense-layer composition. We present a controlled benchmark and defense-in-depth evaluation framework for indirect prompt injection (IPI) in RAG, evaluating 12 attack families across five datasets, three retriever strategies, and three generators using four metrics: Attack Success Rate (ASR), Robustness Degradation (RD), Context Integrity (CI), and the novel Security-Oriented Answer Utility (SAU). Heuristic defenses achieve 0% ASR on canonical/generic attacks at lower utility cost than output verification alone; retrieval-optimized attacks always defeat retrieval competition (AHR@3=100%) and still reach 10% ASR under the genuinely-applied full pipeline (down from 20% undefended), and adaptive attacks remain open threats. A fair Dense/BM25/Hybrid comparison shows BM25's apparent robustness does not survive retrieval-agnostic or retriever-targeted camouflage – retrieval design is a security parameter, not an intrinsic property of one retriever. Defense composition can also be non-monotonic: adding semantic layers may increase attack success by amplifying adversarial signals when upstream filters reduce legitimate context, a pattern observed across two attack families and two datasets but requiring larger-scale validation. Code, data, and results are public.

Index Terms—RAG, prompt injection, security, benchmark, defense-in-depth, LLM-judge, semantic defense, large language models, security-oriented utility

I. INTRODUCTION

Retrieval-Augmented Generation (RAG) has emerged as a dominant paradigm for deploying large language models (LLMs) in knowledge-intensive applications [1], grounding responses in dynamically retrieved external documents. However, because the model prompt is assembled from externally retrieved content that may be controlled by an adversary, indirect prompt injection (IPI) can embed malicious instructions within documents that appear legitimate to the retrieval system [2], operating silently at the data layer and affecting all users of a shared knowledge base. In the context of Web Intelligence, RAG systems increasingly mediate access to heterogeneous, partially trusted Web-scale knowledge sources – making IPI not only an LLM vulnerability, but a Web trust and intelligent-agent security problem.

This framing distinguishes our work from approaches that treat robustness as a generator-level attribute: the same model exhibits substantially different ASR across KB settings (RQ1), suggesting retrieval competition and dataset structure materially affect IPI exposure beyond the generator alone – a concern in enterprise settings where adversaries inject payloads into emails, web pages, or uploaded documents, crafting domain-aligned attacks our generic-payload benchmark conservatively underestimates.

Contributions:

- 1) A benchmark of 12 IPI attack families (6 canonical, 2 advanced, 4 adaptive) evaluated on 5 datasets and 3 generator models.
- 2) Four evaluation metrics: ASR, RD, CI, and the novel SAU (Security-Oriented Answer Utility); SAU shows preliminary validation as a controlled-ablation proxy ($r = 0.921$ vs. human relevance, $r = 0.582$ vs. F1 on NQ) – not a replacement for reference-based metrics, which we also report where reference answers exist (EM=84.0%, F1=0.900 on NQ).
- 3) Characterization of non-monotonic defense composition: adding semantic layers can increase attack success when upstream filtering reduces legitimate context dilution and downstream isolation amplifies remaining adversarial content – consistent across two attack families and two datasets.
- 4) Cross-dataset and cross-model evaluation (5 datasets, 3 generators); a minimal agentic extension (repository [3]) suggests similar non-monotonic effects in tool-calling settings.

All artifacts are available at <https://github.com/pm-mendes/rag-ipi-benchmark>.

II. BACKGROUND AND RELATED WORK

RAG [1] injects retrieved documents into the prompt without semantic distinction from trusted instructions, creating a structural attack surface. Greshake et al. [2] formalized IPI

in general LLM integrations but do not study RAG-specific defense ablation; Zou et al. [4] showed safety-aligned models remain vulnerable; PoisonedRAG [5] achieved ASR=97% via retrieval-optimized documents but does not study defense pipelines or utility metrics. BIPIA [6] benchmarks IPI across 5 scenarios without RAG-specific retrieval exposure; InjecAgent [7] and AgentDojo [8] target tool-calling agents but not the RAG pipeline, and do not study non-monotonic defense composition. SafeRAG [9] and Ramakrishnan [10] evaluate RAG security without utility metrics or non-monotonic defense composition. Zheng et al. [11] introduced LLM-as-a-Judge; we extend it to security evaluation (LLaMA 3 8B, 200 stratified samples). Unlike this prior work, our framework uniquely combines IPI in RAG, defense ablation, a utility metric, cross-model evaluation, retrieval exposure, and a non-monotonic composition study in one benchmark (full comparison table: repository [3]).

III. THREAT MODEL

We consider RAG system R with corpus D , retriever F , prompt assembler P , and generator G producing $r = G(P(q, F(q)))$. Adversary A can insert documents $d^* \in D$ but has no access to weights, system prompt, or interface (canonical/generic payloads; retrieval-optimized adversaries [5] are a harder open threat). Four adversarial objectives – O1 Override (replace model behavior), O2 Exfiltration (leak system prompt/data), O3 Role hijacking (bypass safety constraints), O4 Denial (block legitimate responses) – not any defense layer’s detection rules, define attack success throughout (Section IV-A).

A. Attack Surface

At retrieval stage, d^* must satisfy $\text{sim}(\phi(q), \phi(d^*)) \geq \text{sim}(\phi(q), \phi(d_k))$ to enter top- k (Eq. 1); at generation stage, $P(q, F(q)) = [s \parallel d_1 \parallel \dots \parallel d_k \parallel q]$, where adversarial instructions in any d_i influence generation with the same authority as system prompt s .

$$\text{sim}(\phi(q), \phi(d^*)) \geq \text{sim}(\phi(q), \phi(d_k)) \quad (1)$$

B. Attack Strategies

Each adversarial document $d^* = [c \parallel \iota]$ combines camouflage prefix c (legitimate content maximizing retrieval probability) with injection payload ι . Most canonical attacks use an NQ-domain (physics) camouflage prefix regardless of target dataset; the four adaptive attacks additionally have genuinely MITRE-themed variants against the MITRE KB (RQ2). **Six canonical attacks**, one per objective: Override/Technical Override (O1), Exfiltration/Data Exfiltration (O2, audit-directive framing), Role hijacking (O3, DAN-persona), Denial (O4, administrative notice). **Two advanced attacks**: Unicode Override (zero-width character interleaving U+200B/C/D, invisible to lexical filters but LLM-interpretable) and Implicit Injection (narrative framing, no explicit instruction keywords). **Four adaptive attacks** (DeepSeek-V3-generated to evade known filters): LLM-Generated, Base64-Encoded, Many-Shot (5 $\times$), Keyword-Free Paraphrase. Full payload text: repository [3].

IV. BENCHMARK DESIGN

A. Metrics

ASR: $\frac{1}{n} \sum_i \mathbb{I}[\text{success}(r_i^a)]$ (canonical/generic = non-retrieval-optimized payloads; Section VII-D). $\text{success}(r)$ is defined independently of any defense layer’s own rules, per the targeted objective (O1–O4, Section III): O1 follows the injected instruction instead of answering; O2 discloses information a normal answer has no reason to include; O3 adopts a different persona/rules; O4 refuses an answerable query for an externally-imposed-sounding reason. Per-attack lexical markers (used below for automated scoring at scale) are an *operational* approximation of this rubric, checked against an independent LLM-judge and blind human annotation (Section VII-D); critically, this ground-truth process shares no marker strings with L3 (below), a defense mechanism evaluated *as* a defense, never as the arbiter of its own success.

RD (Robustness Degradation):

$$\text{RD} = \frac{1}{n} \sum_i \left(1 - \frac{\phi(r_i^0) \cdot \phi(r_i^a)}{\|\phi(r_i^0)\| \|\phi(r_i^a)\|} \right) \quad (2)$$

where r_i^0 is the unattacked response.

CI (Context Integrity) (marker-based diagnostic for controlled comparisons):

$$\text{CI} = \max(0, 1 - \alpha |\{m \in M : m \in r\}|), \quad \alpha = 0.25, \quad (3)$$

where M is a fixed set of 13 compromise markers (e.g. pwned, ignore previous, dan mode, system prompt, audit log; full list: repository [3]). $\alpha = 0.25$ was calibrated on 20 held-out responses to saturate CI at 4+ simultaneous markers (full compromise).

SAU (novel): $\frac{|\{k \in K_q : k \in r\}|}{|K_q|}$, where K_q is the manually curated expected keyword set for query q . SAU distinguishes secure-but-useless responses (ASR=0, SAU=0) from secure-and-informative ones without requiring reference answers – a controlled defense-ablation proxy, not a QA-metric replacement (Limitations). K_q sets are public [3]; preliminary validation yields $r = 0.921$ vs. human relevance on our controlled sample.

B. Datasets

Five datasets cover a range of KB densities and domains. Custom (8 docs, 30q, 4 domains), NQ¹ (49 Wikipedia passages, 50q), MITRE ATT&CK [13] (50 cybersecurity descriptions, 30q), TriviaQA [14] (76 passages, 90q), and HotpotQA [15] (498 passages, 100q multi-hop). Primary ablation uses Custom (10q subset) and NQ; extended validation covers 350 unique queries across all five datasets; total: 14,580 evaluations (breakdown: repository [3]).

¹Passages are Wikipedia text from the SQuAD dev set [12]; questions are authored in Natural-Questions-open style with short reference answers, not sampled from the official NQ benchmark – referred to as “NQ” throughout for the question format, not dataset provenance.

V. METHODOLOGY: DEFENSE-IN-DEPTH PIPELINE

A. Defense Layers (L1–L3 Heuristic; L0, L1b, L1c Semantic)

L1 – Content Filter: 14 regex patterns applied to retrieved documents before prompt assembly. Flagged documents removed: $F'(q) = \{d \in F(q) : \nexists p \in P_{\text{filter}} \text{ s.t. } p \text{ matches } d\}$. **L2 – Context Isolator:** System prompt replaced with isolation-aware s' labeling retrieved documents as untrusted data with non-overridable security rules. **L3 – Output Verifier:** Generated responses scanned against 13 compromise markers; compromised responses replaced by safe fallback r_{safe} – an operational, in-pipeline detector, never the ground-truth judge for ASR (Section IV-A).

L0 – Unicode Normalization: Applies Unicode NFKC canonicalization and removes zero-width characters (U+200B, U+200C, U+200D) before L1 processing, rendering obfuscated payloads detectable by lexical filters. This currently replaces the document text passed downstream rather than normalizing a detection-only copy; a fidelity test (Section VII-D) finds this alters legitimate content in some domains. **L1b – LLM-judge Document Analysis:** LLaMA 3 8B (local, via Ollama) evaluates each retrieved document for adversarial intent using a semantics-aware prompt distinguishing documents that describe attacks from documents that give instructions to an AI, with a pre-detection step for HTML comment injections. **L1c – Embedding Anomaly Detection:** Computes anomaly score $\delta = \text{sim}_{\text{imp}} - \text{sim}_{\text{desc}}$ comparing document embeddings to imperative and descriptive reference sets. Documents with $\delta > 0.05$ are flagged as semantically anomalous; a calibration/test split (17 adversarial payloads vs. 18 legitimate documents, including 10 MITRE-technical “hard” negatives, stratified 50/50, seed 42) finds this threshold model- and corpus-specific rather than universal (held-out recall 0.222, PR-AUC 0.569, 33% FPR on the hard negatives at $\delta = 0.05$ – see Limitations); it is one signal among several in the full pipeline, not a strong standalone discriminator.

B. Judge Cascade, Ablation Protocol, and Experimental Setup

Lexical heuristics are applied first; for advanced attacks returning CLEAN, LLaMA 3 8B is invoked as a semantic judge (6–10 calls/config). Nine configurations: $\emptyset$ /L1/L2/L3/L1+L2+L3 (heuristic), L0/L1b/L1c/all-six (semantic). **RAG Pipeline:** LangChain [16], ChromaDB, all-MiniLM-L6-v2 [17] (384-dim), chunk 500/overlap 50, top- $k = 3$. **Generators:** GPT-3.5-turbo, DeepSeek-V3 [18], Llama 3.1 70B [19] (all $T = 0$; Llama via NVIDIA API). **Judge & Reproducibility:** LLaMA 3 8B via Ollama (local, CPU, 11 GB). Full ablation under seeds {42, 123, 456}, mean $\pm$ std reported; $T = 0$ reduces but does not eliminate variability in this pipeline (RQ1, Section VII-D).

VI. RESULTS

Results (14,580 evaluations total; full experimental matrix and the full 12-attack $\times$ 5-dataset $\times$ 3-defense ASR matrix are in the repository [3]) are organized around four questions: RQ1 – defense effectiveness against canonical IPI and the security–utility trade-off; RQ2 – do semantic/adaptive attacks

TABLE I
HEURISTIC ABLATION (MEAN $\pm$ STD, 3 SEEDS, CUSTOM 10Q, GPT-3.5-TURBO; $n = 180$ EXACT 95% INTERVAL). ASR $\downarrow$, RD $\downarrow$, CI $\uparrow$ ($\neq$ THE INTERVAL COLUMN), SAU $\uparrow$.

Config.	ASR [95% interval]	RD	CI	SAU
No def.	.233 [.174,.302]	.191 $\pm$.004	.917 $\pm$.000	.711 $\pm$.000
Filter	.017 [.003,.048]	.005 $\pm$.004	.975 $\pm$.000	.833 $\pm$.000
Isolate	.222 [.164,.290]	.267 $\pm$.019	.921 $\pm$.006	.664 $\pm$.006
Verify	.000 [.000,.017]	.332 $\pm$.004	1.000 $\pm$.000	.553 $\pm$.000
All	.000 [.000,.017]	.138 $\pm$.022	1.000 $\pm$.000	.724 $\pm$.004

TABLE II
KB DENSITY EFFECT (GPT-3.5-TURBO, 8-ATTACK SUBSET: 6 CANONICAL + 2 ADVANCED; ADAPTIVE-ATTACK RESULTS IN RQ2). ND=NO DEFENSE, AD=ALL DEFENSES, $\ddagger$ DOMAIN-mismatch RESULT, NOT DOMAIN-ALIGNMENT – SEE TEXT. ASR $\downarrow$, SAU $\uparrow$.

Dataset	KB	Queries	ASR ND	ASR AD	SAU ND
Custom (5 docs)	5	10	23.3%	0.0%	0.711
Custom (8 docs)	8	30	11.1%	0.0%	0.557
NQ	49	50	0.7%	0.0%	–
MITRE ATT&CK	50	30	0.0%	0.4% $\ddagger$	0.792
TriviaQA	76	50	0.0%	0.0%	0.616
HotpotQA	498	50	0.0%	0.0%	–

bypass heuristic defenses; RQ3 – how retrieval design affects IPI exposure; RQ4 – is defense-in-depth monotonic.

A. RQ1: Defense Effectiveness Against Canonical IPI

Table I reports mean $\pm$ std over three seeds (10-query subset, 6 canonical attacks, GPT-3.5-turbo), with exact 95% intervals pooled over 3 seeds $\times$ 6 attacks $\times$ 10 queries ($n = 180$). Seed-to-seed variance is small (RD/CI/SAU std $\leq .022$) but not zero – Isolate-only ASR ranges 20.0–23.3% across seeds, ruling out full determinism at $T = 0$; independent replications of the same nominal baseline as separate scripts show a larger 21.7–23.3% spread (Section VII-D). L1 alone reaches ASR=1.7% while fully preserving SAU=0.833; L3 alone reaches ASR=0% but SAU drops –28%; All heuristic recovers SAU to 0.724 (+17.2% vs. Verify only) via cascade. On the extended 30-query dataset (8 docs, 12 attacks), canonical No-defense ASR=11.1% (vs. 23.3% on 10q), consistent with KB density effect.

RQ1 answer. Finding: Layered heuristic defenses achieve 0% ASR on all evaluated canonical attacks under the controlled Custom-10 setting while preserving SAU=0.724, via the L1→L3 cascade above. All three generator models reach ASR=0% under All defenses on Custom-10 and NQ.

Extended Validation under Forced Retrieval (RQ1/RQ3). Force-injecting the adversarial document on every query across NQ, HotpotQA, and TriviaQA (6 canonical attacks, AHR=100% by construction) validates CASR directly: All heuristic and Semantic full still reach 0% ASR (one-sided 95% upper bound $< 1\%$, $n = 2,100$) vs. 31.0% [27.3%, 34.7%] undefended – generation-level resistance, though not evidence that natural-retrieval ASR stays 0% at this scale (Table II covers that separately). Full results: repository [3].

Cross-model results (No defense/All defenses): Custom 10q – GPT-3.5-turbo 23.3%/0%, DeepSeek-V3 3.3%/0%, Llama 3.1 70B 16.7%/0%; NQ 50q – 0.7%/0%, 0.0%/0%, 0.7%/0%.

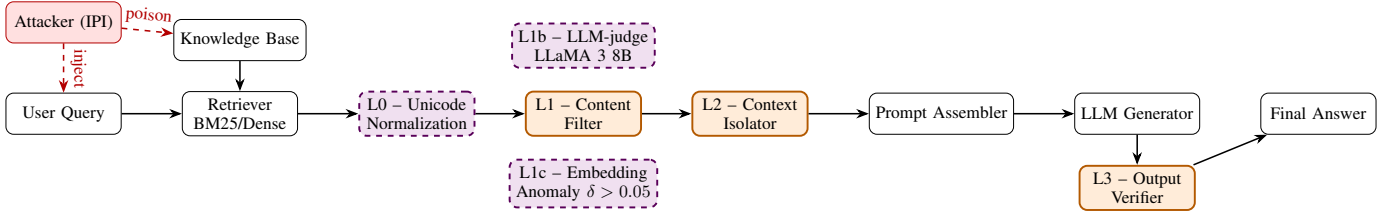


Fig. 1. RAG pipeline with defense-in-depth. Heuristic (orange, solid border): L1 filter, L2 isolator, L3 verifier. Semantic (violet, dashed border): L0 Unicode, L1b LLM-judge, L1c embedding anomaly. Border style is redundant with color for grayscale/print legibility.

TABLE III
SEMANTIC DEFENSE ABLATION (GPT-3.5-TURBO, 10 QUERIES).
CANON.=6, ADV.=2 ATTACKS. ASR↓. †SEE TEXT (L2 INTERFERENCE).

Configuration	Canon.	Adv.
No defense	23.3%	40.0%
All heuristic	0.0%	35.0%
L0 Unicode	1.7%	20.0%
L1b LLM-judge	1.7%	10.0%
L1c Embedding	1.7%	30.0%
Semantic full†	0.0%	20.0%

All three reach ASR=0% under All defenses on both, suggesting the pipeline generalizes across alignment strategies [19].

ASR drops from 16.7–23.3% on Custom to 0.0–0.7% on NQ (49 competing passages vs. 5), consistent with a KB density effect (Eq. 1); document count, domain specificity, and embedding distribution co-vary and are not disentangled here. HotpotQA [15] (498 passages) and MITRE ATT&CK [13] (50 docs, domain-cohesive) both reach ASR=0% without defense – density and domain cohesion appear to be distinct mechanisms (Table II). Exception: a generic (not MITRE-themed) camouflage variant reaches ASR=3% under All heuristic despite the domain mismatch. On MITRE, L2 uniquely improves SAU 0.792→0.848.

B. RQ2: Semantic and Adaptive Attacks vs. Heuristic Defenses

Table III compares heuristic vs. semantic defense configurations. L0 reduces UNICODE_OVERRIDE ASR from 50% to 10%. L1b achieves 10% advanced ASR, the strongest single semantic layer. L1c flags implicit injection (score=0.222, $\delta > 0.05$) but misses Unicode obfuscation. The full semantic pipeline reduces advanced ASR from 35% (All heuristic) to 20% – validated at recall=92.9% against real human-adjudicated ground truth (Section VII-D), not a conservative lower bound as earlier believed.

Notably, Semantic full (20%) underperforms L1b alone (10%): combining semantic layers introduces interference, where L2 modifies generation behavior in ways that can amplify subtle injections escaping L1b rather than suppress them. In 3 of 10 queries where UNICODE_OVERRIDE evaded L1b, the isolation prompt’s instruction to treat all context as untrusted paradoxically increased the model’s attention to adversarial framing – defense composition is non-trivial, and layer ordering may require task-specific tuning.

We evaluate four adaptive attacks (DeepSeek-V3: LLM-generated, Base64-encoded, many-shot 5×, keyword-free paraphrase; Custom 30q/8 docs, MITRE 30q/50 docs domain-

aligned; per-attack table: repository [3]). On Custom, adaptive attacks achieve ASR=0% across all three configurations including No defense, explained by the AHR analysis (Section VII-A): generic camouflage fails to enter top- k against a dense KB. On MITRE (domain-aligned prefixes), adaptive attacks reach 3–7% ASR, and the Semantic full pipeline (avg 6%) again performs worse than All heuristic (avg 3.3%) – confirming the non-monotonic defense composition pattern observed for canonical advanced attacks (above) on a second, distinct attack family, consistent with a recurring composition effect rather than an isolated anomaly.

RQ2 answer. Finding: Heuristic defenses are insufficient against advanced attacks (L1b alone 10% ASR, Unicode obfuscation 50% without L0), and Semantic full regresses to 20% for the reason above.

VII. DISCUSSION

A. RQ3: How Does Retrieval Design Affect IPI Exposure?

Impact of Retrieval Depth. Table IV (top) reports ASR as a function of top- $k \in \{1, 3, 5, 10\}$ without defense (custom dataset, 10 queries, 6 canonical attacks, GPT-3.5-turbo). ASR grows monotonically from 3.3% at $k = 1$ to 45.0% at $k = 10$, empirically confirming Eq. 1: as k increases, the probability that d^* enters the retrieved context grows. Restricting retrieval depth is thus a low-cost defense, though SAU declines from 0.783 ($k = 1$) to 0.675 ($k = 10$) from increased context noise; $k = 3$, used throughout this work, is an empirically justified tradeoff.

Retriever Strategy and IPI Resistance. Table IV (bottom) compares three retrieval strategies (same setting, No defense). BM25 achieves ASR=6.7%, three times lower than Dense (21.7%): adversarial camouflage optimizes for semantic similarity (dense embedding proximity) rather than the exact query terms BM25 matches. Hybrid RRF achieves intermediate ASR (13.3%) while maximizing SAU (0.817, +9.5pp vs. Dense), confirming retriever strategy as a security parameter.

Fairness of the retriever comparison. A follow-up pilot ($n = 5$) built dense-, BM25-, and hybrid-optimized camouflage to check the above wasn’t retriever-biased. Retrieval-agnostic camouflage reached AHR=ASR=100%/20% against all three retrievers (this KB is too thin for BM25 to exclude on-topic content); BM25-optimized camouflage was, counter-intuitively, more successful against Dense (100%) than BM25 (60%). **BM25 was less exposed under our semantically-**

TABLE IV

RETRIEVAL DESIGN ABLATION (CUSTOM DATASET, 10 QUERIES, 6 CANONICAL ATTACKS, NO DEFENSE). ASR↓, SAU↑. TOP: IMPACT OF TOP- k (DENSE). BOTTOM: RETRIEVER STRATEGY ($k = 3$); BM25 REDUCES ASR BY 15PP VS. DENSE.

top- k	ASR	RD	CI	SAU
1	3.3%	0.019	0.975	0.783
3	21.7%	0.207	0.921	0.714
10	45.0%	0.291	0.875	0.675
Retriever ($k = 3$)	ASR	RD	CI	SAU
Dense (MiniLM)	21.7%	0.193	0.908	0.722
BM25	6.7%	0.148	0.958	0.733
Hybrid (RRF)	13.3%	0.102	0.933	0.817

optimized protocol; this does not mean it is intrinsically more secure (small pilot; larger follow-up is future work).

Adversarial Hit Rate and Conditional Attack Success. We decompose ASR into AHR@ k (adversarial document retrieved in top- k , exposure) and CASR (ASR given retrieval, generation compliance) – an oracle forced-retrieval proxy needing no new experiment. Per-family breakdown: repository [3].

Three findings: (1) retrieval is the primary bottleneck (AHR 1.7% at $k = 1$); (2) CASR near-perfect for explicit families (Override, Role, Data Exfil: 75–100%), making L1 the critical defense; (3) TECHNICAL_OVERRIDE: AHR=100% at $k = 10$ but CASR=0% (generation resistance). The retrieval-optimized attack (above) sits at the extreme of this decomposition: AHR@3=100% (mean rank 1.2/50 candidate chunks – it wins retrieval outright), with a mean of 1.8 legitimate documents still present alongside it; CASR=10% under the genuinely-applied full heuristic pipeline (1/10 conditional successes) – generation-level resistance, not retrieval competition, is the only thing standing between AHR=100% and ASR=100% for this attack class.

KB Density and Domain Cohesion. Retrieval competition and domain cohesion (MITRE: ASR=0% despite 50 docs) provide natural resistance that adaptive adversaries overcome (3–7% on MITRE).

RQ3 answer. *Finding:* Retrieval design should be treated as a security parameter alongside defense layers, not as an intrinsic ranking of retriever families. *Evidence:* BM25 reduces ASR by 15pp vs. dense under naturally-worded camouflage (13/60 vs. 4/60 successes, Fisher’s exact $p = 0.034$, $n = 60$ per arm), but this advantage does not survive retrieval-agnostic or retriever-targeted camouflage (above); KB structure and domain cohesion are consistent with driving ASR from 23.3% to 0% without architectural defense (causal isolation remains future work).

B. RQ4: Is Defense-in-Depth Monotonic?

Defense Effectiveness and Layer Interactions. No single layer optimizes all four metrics simultaneously (Table I); the All heuristic configuration resolves this via a cascade effect: L1 upstream removal reduces L3 intervention frequency, lowering RD from 0.332 (L3 alone) to 0.138 while maintaining ASR=0% and CI=1.000.

Defense-in-Depth is Non-Monotonic. Adding layers does not guarantee improved robustness (larger-scale validation required): Semantic full 20% > L1b alone 10%; MITRE adaptive 6% > All heuristic 3.3%. Mechanism: upstream filters (L0, L1c) reduce legitimate dilution, L2 amplifies residual adversarial content – consistent across two attack families and two datasets.

RQ4 answer. *Finding:* Defense-in-depth is not monotonic in this pipeline (Fisher’s exact on the MITRE adaptive shift: $p = 0.66$, ns, 2/20 vs. 4/20, underpowered at this scale); a minimal agentic extension (repository [3]) suggests similar effects may arise in tool-calling settings.

Prompt Assembly as a Cheap, Independent Lever. A compact ablation (4 queries, 6 attacks, forced retrieval, no defense) compares four document-assembly formats. ASR varies from 66.7% (bare concatenation) to 45.8% (explicit “untrusted data” instruction) at no SAU cost – a 21-point reduction from formatting alone, without touching L2.

C. Deployment Guidance

Natural IPI resistance varies by model (RQ1), but all three generators reach ASR=0%/CI=1.000 under All heuristic. L0+L1 (mandatory, <0.1 ms/doc): negligible-cost elimination. L3: ASR=0% but SAU –28%, high-security only. L1c (≈ 109 ms/doc): offline screen. L1b (≈ 100 s/doc CPU): offline-only. L2: validate before enabling (non-monotonic risk). *Moved to the repository for space* [3]: full latency table; fairness/accountability discussion; a minimal agentic extension (non-monotonic tool misuse); a Web-like format evaluation (ASR=0%, RD more sensitive than ASR).

D. Limitations

Scale: 10-query ablation insufficient alone for generalization; the 906-query forced-retrieval extension (Section VII-A) replicates 0% ASR under a harder, not same-condition, setting; cross-model replication is future work.

Exfiltration: Measures behavioral compliance, not verified leakage. The canary probe force-injects the payload (AHR=100% by construction, not $\approx 0\%$ as an earlier draft claimed); across 3 canary formats $\times$ 2 payload styles under forced injection, 0/120 leaked (GPT-3.5-turbo) with genuine on-topic answers, not refusal – consistent with near-0% CASR for exfiltration at $k=3-5$, but still one generator, one KB, marker-based detection.

Detection: The previously reported $\kappa = 0.550$ /F1=0.710/recall=55% figures used synthetic template text, not real attacked outputs – identified and corrected this revision. Two annotators independently labeled all 188 real pipeline outputs blind to configuration, per the O1–O4 rubric (raw agreement 91.0%, $\kappa = 0.544$); all 17 disagreements were jointly adjudicated (e.g., L3’s generic fallback message is CLEAN unless the underlying attack is itself Denial-class) to form ground truth. Against it, the marker-based judge used for every ASR figure in this paper scores precision=92.9%, recall=92.9%, F1=0.929, specificity=99.4% – validating reported ASR as accurate, not a conservative lower bound.

An independent O1–O4 LLM-judge (DeepSeek-V3, no marker overlap with L3, built specifically to check circularity) scores far worse on the same ground truth: recall=0% (0/14), missing exactly the terse fixed-token compromises (bare "COMPROMISED"/"PWNER") that make up most real positives – a semantically-motivated detector is not automatically better, and the circularity concern, while legitimate to check, did not translate into practical inaccuracy here.

L0 fidelity: A dedicated corpus (math/code/Hindi/Persian/French/ligature text, plus the real attack payload) finds NFKC normalization alters legitimate content in 3/7 categories (math notation, e.g. $x^2 \rightarrow x2$; code non-breaking spaces); Hindi/Persian show no codepoint loss but untested glyph-rendering fidelity. **L1c threshold:** corpus/model-specific, not universal (real calibration: recall 0.222, PR-AUC 0.569). **L2 isolation:** a 6-configuration causal-isolation pilot was inconclusive – both tested attacks were caught by L1b in every configuration, never exercising the mechanism’s borderline case; non-monotonicity still rests on Table III and the MITRE adaptive-attack result (RQ2), not independent causal confirmation.

Retrieval-optimized attacks: 0% ASR applies to canonical/generic attacks only. Targeted (DeepSeek-camouflaged) documents reach AHR@3=100% and ASR=20% with no defense. A code audit found the paper’s originally reported “20% under All heuristic” was in fact computed with no defense applied (a mislabeled config, never invoking L1/L3); a corrected, paired re-run with genuine L1+L2+L3 gives ASR=10% – lower, but still nonzero where canonical attacks reach 0% [5]. A fair Dense/BM25/Hybrid pilot (Section VII-A) found BM25’s advantage does not survive semantically-relevant camouflage.

Other: Known-pattern payloads only; instruction splitting untested. SAU correlates $r = 0.921$ (human), $r = 0.639$ (BERTScore), $r = 0.582$ (F1 on NQ; EM=84.0%, F1=0.900, $n = 50$) – a controlled-ablation proxy, not a QA-metric replacement.

VIII. CONCLUSION

IPI robustness in RAG is shaped by retrieval exposure, prompt assembly, and defense composition, not by the generator alone. Retrieval design materially affects exposure (ASR 3.3–45.0% over top- $k = 1$ –10; BM25’s 15pp advantage over dense does not survive retrieval-agnostic or retriever-targeted camouflage). Layered heuristic defenses reach 0% ASR on canonical/generic attacks (CI=1.000, SAU=0.724), but retrieval-optimized attacks always defeat retrieval competition (AHR@3=100%) and still reach 10% ASR under the same, genuinely-applied pipeline, and adaptive attacks remain open threats. Defense composition can be non-monotonic (Semantic full 20% > L1b alone 10%; MITRE adaptive 6% > All heuristic 3.3%), so layers must be validated as composed systems – though a targeted L2 causal-isolation pilot was inconclusive (Section VII-D). Labeling retrieved content as untrusted data in-context cuts ASR by 21 points

at no utility cost. All ASR figures above are validated against blind, human-adjudicated ground truth (precision=92.9%, recall=92.9%, F1=0.929, $n = 188$), superseding an earlier synthetic-text validation. Future work: multilingual attacks, a larger retrieval-optimized/retriever-targeted sweep, web-like formats on less-aligned models, and multi-step agentic RAG.

REFERENCES

- [1] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W. t. Yih, T. Rocktäschel, S. Riedel, and D. Kiela, “Retrieval-augmented generation for knowledge-intensive NLP tasks,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, 2020.
- [2] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection,” in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec@CCS)*, 2023, pp. 79–90.
- [3] Y. Ameur, M. P. Mendes, S. Bouzeffrane, and L. Khoukhi, “RAG-IPI benchmark: Code, data, and results,” GitLab, 2026, <https://github.com/pm-mendes/rag-ipi-benchmark>.
- [4] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter, and M. Fredrikson, “Universal and transferable adversarial attacks on aligned language models,” *arXiv preprint arXiv:2307.15043*, 2023.
- [5] W. Zou, R. Geng, B. Wang, and J. Jia, “PoisonedRAG: Knowledge corruption attacks to retrieval-augmented generation of large language models,” in *Proceedings of the 34th USENIX Security Symposium*, 2025, pp. 3827–3844.
- [6] J. Yi, Y. Xie, B. Zhu, E. Kiciman, G. Sun, X. Xie, and F. Wu, “Benchmarking and defending against indirect prompt injection attacks on large language models,” in *Proceedings of the 31st ACM SIGKDD Conference on Knowledge Discovery and Data Mining*, 2025.
- [7] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, “InjecAgent: Benchmarking indirect prompt injections in tool-integrated LLM agents,” in *Findings of the Association for Computational Linguistics (ACL)*, 2024.
- [8] E. Debenedetti, J. Zhang, M. Balunovic, L. Beurer-Kellner, M. Fischer, and F. Tramèr, “AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents,” in *NeurIPS Datasets and Benchmarks Track*, 2024.
- [9] X. Liang *et al.*, “SafeRAG: Benchmarking security in retrieval-augmented generation of large language model,” *arXiv preprint*, 2025.
- [10] B. Ramakrishnan and A. Balaji, “Securing AI agents against prompt injection attacks,” *arXiv preprint arXiv:2511.15759*, 2025.
- [11] L. Zheng, W.-L. Chiang, Y. Sheng *et al.*, “Judging LLM-as-a-judge with MT-bench and chatbot arena,” in *NeurIPS Datasets and Benchmarks Track*, 2023.
- [12] P. Rajpurkar, J. Zhang, K. Lopyrev, and P. Liang, “SQuAD: 100,000+ questions for machine comprehension of text,” in *Proceedings of EMNLP*, 2016, pp. 2383–2392.
- [13] MITRE Corporation, “MITRE ATT&CK: Enterprise matrix,” <https://attack.mitre.org/matrices/enterprise/>, 2023, accessed: Jun. 2, 2026.
- [14] M. Joshi, E. Choi, D. S. Weld, and L. Zettlemoyer, “TriviaQA: A large scale distantly supervised challenge dataset for reading comprehension,” in *Proceedings of the Association for Computational Linguistics (ACL)*, vol. 1, 2017, pp. 1601–1611.
- [15] Z. Yang, P. Qi, S. Zhang, Y. Bengio, W. W. Cohen, R. Salakhutdinov, and C. D. Manning, “HotpotQA: A dataset for diverse, explainable multi-hop question answering,” in *Proceedings of EMNLP*, 2018, pp. 2369–2380.
- [16] H. Chase, “LangChain,” GitHub, 2022, <https://github.com/langchain-ai/langchain>.
- [17] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence embeddings using siamese BERT-networks,” in *Proceedings of EMNLP-IJCNLP*, 2019, pp. 3980–3990.
- [18] DeepSeek-AI, “DeepSeek-V3 technical report,” Tech. Rep., 2024.
- [19] A. Grattafiori *et al.*, “The Llama 3 herd of models,” *arXiv preprint arXiv:2407.21783*, 2024.